Mizan Security Strategy v2.1 — Proposed

Breach-tolerant design goal — not a security guarantee
Version: 2.1 · **Date:** 11 November 2026
Status: Proposed strategy and roadmap; **not an implementation, certification, or guarantee**
Audience: Founders, Product, Engineering, DevSecOps, security reviewers

> This document describes intended design and evidence gates. It does not assert that the controls below are implemented or enabled in any Mizan deployment. Implementation status must be established from source, configuration, tests, and deployment-specific evidence. No external security claim should exceed that evidence.

1. Position in one page

Mizan helps organisations manage AI costs, customise models with approved business knowledge, and run AI on infrastructure they control. Security is a foundational product requirement.

No system is unbreakable. The v2.1 objective is to reduce the likelihood and impact of compromise: a single stolen credential, compromised service, mistaken employee, malicious document, or compromised Sentinel component should have a bounded blast radius, produce detectable signals, and have a documented recovery path. This is a design objective to be validated—not a claim that one compromise cannot expose a tenant.

Version 2.1 incorporates the v1 review and the v2 review: it clarifies failure behavior for unclassified data, makes acceptance tests observable and repeatable, and adds role owners, status fields, and release gates in the companion checklist. The proposed measures remain subject to feasibility review and implementation.

2. Governing rules

1. **Avoid single points of trust.** No one person, key, service, AI model, or Sentinel component should alone read tenant content, change policy, contain a tenant, sign a release, or restore service.
2. **Default deny, enforced server-side.** A UI action cannot override policy. Unapproved data flows, destinations, tools, and packages are rejected.
3. **Assume breach.** Every control needs a detection signal, containment unit, and recovery path.
4. **Contain narrowly.** Isolate the affected account, token, agent run, or service before considering tenant-wide action. Platform-wide action is exceptional and dual-authorised.
5. **Claims follow evidence.** Say “planned” until implemented; say “tested” only with scope and results; claim independent assessment or certification only when documented and current.

3. Weakness-to-fix summary

v1 weakness	Proposed v2 treatment
Sentinel is a high-value target	Separate Detect, Decide, and local Act; short-lived signed scoped orders
Undefined failure behavior	Explicit dependency-failure matrix; unknown/confidential data fails closed
Thin key management	Key hierarchy, separate signing purposes, rotation/revocation/recovery; customer-managed keys only where actually supported

v1 weakness	Proposed v2 treatment
Logging/privacy conflict	Metadata-first events; separately protected, time-limited sealed evidence where needed
Rollback downgrade risk	Signed minimum-version floor in addition to revocation checks
Support access unclear	Customer-approved just-in-time access broker
Severity and response clocks unclear	Severity definitions, configured acknowledgement targets, escalation and regulatory clocks
Alert flooding	Deduplication, correlation, source rate limits, burst detection
Recovery exception loophole	Two-person Sev1 recovery, with an independent reviewer
AI threats incomplete	Prompt injection, unsafe output, SSRF, retrieval authorization, tool scope, and resource abuse tests
Backup ransomware risk	Immutable/offline copies with separate credentials and restore drills
Metrics lack baselines	Baseline first; approve targets only after measurement
No disclosure policy	Named vulnerability intake, triage, disclosure, and bounty decision
Pen-test scope unclear	Written rules of engagement and explicit system boundaries
Framework mapping absent	Select target framework(s) and collect evidence early

4. Sentinel: proposed three-part separation

Sentinel can influence workload containment and must not be a single all-powerful component.

Part	May do	Must not do
Detect	Read security events, correlate signals, raise incidents, draft AI summaries	Change policy, revoke access, or execute containment
Decide	Evaluate deterministic policy and issue short-lived, signed, single-tenant orders	Execute orders, read tenant content, or act across tenants alone
Act (local runtime enforcer)	Execute a valid order scoped to its tenant, target, action, expiry, and nonce	Accept unsigned, expired, wrong-tenant, out-of-scope, or replayed orders

Orders should contain tenant ID, target, action, expiry, and unique nonce. Enforcers reject replay. Per-tenant limits cap action volume. Cross-tenant or platform-wide actions require two authorised people and an offline-held key. AI may summarize and recommend; it must not grant permissions, suppress incidents, delete logs, or perform destructive action. Sentinel needs its own threat model, privileged-access model, deployment pipeline, and recovery procedure. A missed heartbeat is a signal, not evidence of a quiet system.

Open design work: define signing quorum, key custody, clock-skew tolerance, revocation distribution, nonce persistence, queue saturation behavior, and how the Decide component remains independent from the signing authority.

5. Fail-behavior matrix

Confidentiality takes precedence. Low-risk local work may continue only under bounded, valid policy. This matrix is proposed and must be tested for every protected operation and relevant combination of failures.

Operation	Policy engine down	Classifier down	Sentinel unreachable	Key service down	Network cut
Transfer of Confidential/Restricted data	Fail closed	Fail closed	Fail closed	Fail closed	Block
Transfer of Public data	Use only unexpired signed cached policy; log	**Allow only data already classified Public, tied to an integrity-protected approved version and digest. New, changed, unknown, or unclassified data is quarantined/blocked.**	Allow only previously authorised Public flow; log/queue	Allow only if required cached key is valid	Queue only if destination/polic approval is already valid; otherwise block
Local inference on approved model	Last signed policy until tenant max age; then read-only	Run only for approved inputs; label/flag output; unclassified new input follows tenant policy	Continue bounded local operation; queue protected events	Continue only with a valid cached key; otherwise stop protected operation	Run local-only; queue encrypted ordered events
New data upload	Quarantine; do not process	Quarantine; do not classify/export	Accept only to quarantine; no processing	Reject if encryption/attestation needs key	Reject or quarantine locall per deployment policy
Model package install/update	Reject	Reject	Reject	Reject	Reject
Admin or policy change	Reject	Reject	Reject	Reject	Reject
High-impact agent tool call	Deny	Deny	Deny	Deny	Deny
Low-impact allowlisted local tool	Run within budget and scope	Run only if input classification permits	Run within budget; queue events	Run only if valid local credentials remain	Run only if local and already authorised

Additional rules: policy age limits are set per tenant; beyond the limit, degrade to read-only. Local event queues are encrypted, hash-chained, bounded, and delivered in order after recovery. Queue full, invalid signature, uncertain

classification, or expired policy must not silently downgrade to allow. Any exception is explicit, time-limited, approved, and logged.

6. Key hierarchy and cryptographic governance

Layer	Purpose	Proposed protection
Root of trust	Anchors key hierarchy	Offline or HSM; threshold access
Tenant master key	Wraps tenant data keys	BYOK/HYOK only where implemented and supported; otherwise state the actual custody model
Tenant data keys	Encrypt datasets, embeddings, artifacts, and logs	Per-tenant and data-class separation; rotation and revocation
Signing keys	Sign packages, builds, policies, and containment orders	HSM or offline custody; threshold approval; separate purpose keys
Service credentials	Workload identity	Short-lived, automatically rotated, never shared

Mizan staff should not be able to decrypt tenant data alone. Key administration is separated from application and log administration. Signing-key compromise requires revocation, trust-anchor replacement, re-signing, and a new minimum-version floor. Tenant-key compromise triggers scoped re-encryption and review/invalidation of affected backups. Rotation, revocation, key loss, and restore procedures must be exercised. Use reviewed cryptographic libraries; no custom cryptography. Do not claim HSM, BYOK, or HYOK capability until implemented and deployment-tested.

7. Logging and privacy

Record what happened by default, not document contents: incident ID, timestamp, source, identity, tenant, resource, action, policy, decision, and response. Refer to content by hash or protected pointer. Where content is essential for investigation, seal it under a separate evidence key; release it only with two-person approval and delete it on an approved fixed schedule. Log and review evidence access. Store audit logs in tamper-evident/write-once storage administered separately from the application. Never log passwords, tokens, or private keys. Review employee monitoring, notice, jurisdiction, and retention with legal/HR before launch.

8. Supply chain and anti-rollback

- Sign packages and manifests; record provenance and SBOM; make builds reproducible where feasible.
- Require two-person release approval; use hardened CI/CD, ephemeral builders, and no long-lived build secrets.
- Runtime verifies signature, provenance, checksum, package format, and policy before installation.
- Distribute a signed minimum-version floor; reject versions below it, including otherwise valid signatures. Rollback only to a non-revoked version at/above the floor, and log it.
- Prefer non-executable model formats (e.g. safetensors); reject pickle-style or otherwise executable formats; scan artifacts before load.
- Pin dependencies, scan for vulnerabilities, and define patch SLAs.

9. Support access broker

Mizan staff hold no standing access to customer environments. Support requests access with a reason and ticket; customer admin approves scope and duration; broker issues expiring, single-purpose credentials; the session is recorded and visible to customer; Restricted-data access requires a second Mizan approver. Break-glass is rare, alarmed, time-limited, and reviewed afterward. This flow requires a tested customer revocation and expiry path.

10. Incident handling: severity, clocks, recovery

Severity	Definition	Immediate action	Acknowledgement target	Escalation
Sev1	Confirmed compromise, confirmed exposure, or active attack	Scoped containment now; do not wait for a person	Per tested customer contract	Next accountable role, then executive and customer contact
Sev2	High-confidence policy violation or likely compromise	Block action; revoke affected token/session	Per tested customer contract	Backup responder
Sev3	Low-impact blocked violation	Block, record, review	Next business cycle, if adopted	Security lead
Sev4	Low-confidence anomaly	Record and increase observation; no destructive action	Review queue	None unless correlated

Targets shown here are placeholders, not SLAs. Set values per contract only after delivery testing. Regulatory and contractual clocks start at awareness and are recorded against the incident. Deduplicate, correlate, rate-limit per source, and detect bursts. Notify via primary and independent backup channels; log delivery and acknowledgement without secrets or document content. Sev1 restoration requires two authorised people, at least one not responsible for the triggering change. Verify integrity, credentials, policy, and data before return to service.

11. AI security controls

Risk	Proposed control and test focus
Direct prompt injection	Treat input as untrusted; separate instructions/data; constrain tools
Indirect injection from RAG/documents	Retrieved text is data, never authority; strip active content; cannot grant permissions
Unsafe output	Validate and sandbox SQL, shell, HTML, and URL arguments outside the model
SSRF	Egress allowlists; block internal ranges; resolve and re-check destinations
Sensitive disclosure	Check authorization at retrieval and response time outside model
Cross-tenant RAG	Enforce user and tenant scope in retrieval layer; never trust model metadata
Prompt/config leakage	Do not expose system configuration or secrets in prompts
Unsafe tool use	Allowlist tools; scope credentials; validate arguments; gate high-impact actions
Loops/resource abuse	Per-run budgets, timeouts, call limits, run-scoped kill switch

Risk	Proposed control and test focus
Training poisoning/extraction	Controlled sources, lineage, reproducibility; minimize sensitive training data and restrict export

Each agent needs its own identity, tool allowlist, data scope, and budget. A model is never a security authority.

12. Data, tenancy, and resilience

Maintain inventory of uploads, masked data, prompts, outputs, embeddings, indexes, logs, checkpoints, backups, and support diagnostics with owner, classification, location, retention, and processors. Enforce tenant isolation across database, object store, vector store, queues, caches, logs, and model artifacts, with cross-tenant negative tests. Run document parsing, evaluation, and training in disposable, network-restricted sandboxes. Use RAG for changing/access-controlled knowledge; fine-tuning for behavior/terminology; do not put confidential records into model weights by default. No shared-model training on customer data without written authorization. Maintain immutable offline backups with separate credentials; schedule measured restore drills from verified clean state. Verify every telemetry/licensing/backup/support/model-download/control-plane path before making residency or "stays in your environment" claims.

13. Acceptance tests and release evidence

Every test is run in isolated staging or a dedicated test tenant, with synthetic data, recorded build/config, logs, timestamps, and reviewer. A release gate passes only when the result is repeatable and evidence is attached; UI display alone is not evidence of enforcement.

ID	Acceptance test	Measurable pass condition
T-01 Default-deny transfer	Exercise approved and unapproved destinations, including client-side "accept" override attempt	100% of unapproved Confidential/Restricted transfer attempts are denied server-side; approved Public flow succeeds only under its signed policy
T-02 Incident registration	Trigger each synthetic violation class	Each trigger creates one uniquely identified complete protected record; required fields present; no secret/content leakage
T-03 Notification	Send a synthetic alert through primary and backup routes	Both routes produce delivery receipts within the configured tested target; no secrets/content included
T-04 Escalation	Leave synthetic incident unacknowledged	Escalation occurs at configured time; event and recipient recorded
T-05 Scoped containment	Simulate compromised test workload in one tenant	Target workload is isolated; unrelated workload and second tenant remain available; scope recorded
T-06 Order integrity	Try valid, unsigned, expired, replayed, wrong-tenant, and wrong-target orders	Valid scoped order executes once; every invalid order is rejected and logged
T-07 Sentinel compromise	Simulate compromise of Detect and separately Decide	Neither component alone reads tenant content or performs out-of-scope/cross-tenant containment
T-08 Fail behavior	Inject each dependency failure and pairwise high-risk failures	Every matrix cell has expected outcome; unclassified/unknown data never transfers; queues are bounded and alert on overflow

ID	Acceptance test	Measurable pass condition
T-09 Anti-rollback	Install below-floor, at-floor, revoked, and valid current packages	Below-floor/revoked packages reject; at-floor/current packages follow signature and policy checks
T-10 Log protection	Attempt update/delete using application credentials; verify evidence channel	Attempts fail; protected records remain hash-verifiable; evidence access is separately logged
T-11 Monitoring silence	Stop event collection/heartbeat in test environment	Alarm or defined safe mode occurs within configured detection interval; missing telemetry is never reported as healthy
T-12 Support broker	Attempt access without approval; then with scoped approval	Unapproved access denied; approved access limited to scope/time, recorded, and automatically expires
T-13 Key compromise	Revoke synthetic key and restore/re-encrypt test data	Old key/orders rejected; rotation/re-encryption completes; affected backups handled per procedure
T-14 Tenant isolation	Attempt cross-tenant access across every data/resource class	100% of unauthorized attempts denied with expected non-enumerating response; no data in response/logs
T-15 AI tool limits	Try unapproved tool, excessive calls, scope escape, and high-impact action	All prohibited calls denied server-side; limits/kill switch trigger and leave audit evidence
T-16 Indirect injection	Insert synthetic malicious instruction in retrieved content	It cannot change permissions, policy, tool scope, or execute a prohibited action
T-17 Unsafe model file	Upload synthetic executable/pickle-style artifacts and safe control files	Unsafe files rejected before load; safe supported formats continue through manifest checks
T-18 Recovery	Exercise Sev1 restore using separate test identities	Two distinct authorised people approve; triggering actor alone cannot restore; integrity checks pass
T-19 Backup	Simulate admin compromise and restore from immutable/offline copy	Compromised admin cannot erase copy; restore digest/schema/data checks pass within approved RTO/RPO

Release thresholds, timeout values, recipients, RTO/RPO, and sampling sizes must be set and approved for each deployment before declaring a pass. Do not invent performance or SLA targets before baseline measurement.

14. Assurance programme

Maintain threat models per plane, including Sentinel. Automate negative access/tenancy/data-route tests in CI. Run red/purple-team exercises including Sentinel compromise and alert floods. Commission an independent penetration test under written scope covering Control Plane, Data Plane, Customer Runtime, Sentinel, and release pipeline. Publish a vulnerability disclosure intake and triage policy; consider bounty after pilot. Run an incident tabletop. Select SOC 2 and/or ISO 27001 mapping early. Baseline MTTD, MTTC, block-before-completion, delivery, false-positive/negative, revocation, recovery, and asset-coverage metrics before setting targets.

15. Proposed roadmap and release gates

Phase	Scope	Exit evidence
0 Foundations	Inventory, boundaries, threat models, fail behavior, keys, framework and deployment decisions	Approved architecture, named owners, risk backlog, testable configuration
1 Secure core	MFA/RBAC, tenancy, encryption/keys, default deny, protected logs/secrets	Applicable T-01, T-10, T-13, T-14 pass in target environment
2 Sentinel MVP	Detect/Decide/Act, signed orders, incidents, notifications, scoped containment	T-02–T-08 and T-11 pass in simulated incident
3 Supply chain/runtime	Signed packages, SBOM, anti-rollback, support broker, hardened runtime	T-09, T-12, T-17 pass; runtime deployment evidence
4 AI security	Agent identity, tools, injection/output controls, isolated parsing	T-15/T-16 pass; attack simulations reviewed
5 Enterprise hardening	Offline backups, recovery, independent test, VDP, compliance and runbooks	T-18/T-19 pass; critical independent findings resolved

Proposed release gates: **G0 Architecture** (phase 0 approved); **G1 Sensitive-data pilot** (secure-core evidence and customer data boundaries); **G2 External processing/RAG** (Gate 1 approvals, transfer fail-safe, AI/RAG tests); **G3 Runtime/release** (signed packages, anti-rollback, runtime/Golden tests); **G4 Enterprise assurance** (recovery, independent test, vulnerability disclosure, framework evidence). These are proposed gates and must be adopted by accountable owners.

16. Ownership placeholders

Use role ownership until named individuals are formally assigned: Product Owner; Security Lead/Incident Commander; Platform/DevSecOps; Application/AI Engineering; Customer Administrator; Independent Assessor. Each deployment must name primary and backup responders and define which actions require customer approval. No critical process should depend on one person.

17. Decisions required before implementation commitments

Decide deployment modes; data categories permitted in each plane; whether/where raw data is stored and retained; IdP/SSO/MFA; tenant isolation design; approved destinations; containment unit and automatic actions; HSM/KMS and BYOK/HYOK scope; evidence retention/legal review; RTO/RPO; framework/regulatory markets; and independent assessment needed before enterprise pilot.

18. Claims discipline and status definitions

Evidence state	Permitted wording
Proposed / not implemented	“We plan to implement…”
Implemented, not fully tested	“Implemented; validation in progress.”
Tested internally	“Tested under these named scenarios and environment…”
Independently assessed	“An independent assessment covered this defined scope…”
Certified	Only after award and while certificate is valid

Avoid “unbreakable,” “unhackable,” “100% secure,” “prevents all attacks,” and “data can never leave your environment.” The companion checklist is the traceability record; its statuses are evidence-led and do not inherit claims from this strategy.

Review note: This document remains a discussion draft. Validate feasibility, choose technology, estimate effort, assign owners, and obtain specialist security review before implementation or external claims.